Week 5 Defense Script

Danial Rahman, CS-2421. About 7–8 minutes at a measured pace, including a short demonstration. Divide sections between group members if necessary. Rehearse with a timer and review the saved query results before presenting.

Topic and weekly objective 0 to 1 minute

Hello. Our group topic is Detecting Spearphishing Attacks in Corporate Networks. In Week 4, we organized the RSA case using the Cyber Kill Chain. For Week 5, we move to a practical hunting question. We want to investigate suspicious PowerShell activity connected to Office applications.

The syllabus asks us to build a hypothesis-driven hunting scenario and execute queries in Splunk or ELK. We chose Splunk for the executed demonstration. We prepared a small dataset, ran four searches and reviewed the results. The dataset is synthetic. It represents a controlled exercise, rather than activity from an actual company.

Our weekly result is a reproducible hunt with a clear hypothesis, narrowing queries and an analyst decision for each matching host.

Explain the hypothesis 1 to 2 minutes

Our hypothesis is that a suspicious Office workflow may launch PowerShell with an encoded command argument and create an outbound connection from that same PowerShell process within ten minutes.

This is a useful question because PowerShell can be used for both administration and attacker execution. We cannot classify every PowerShell process as malicious. We need to consider its parent process, command line and related network activity.

An intelligence-driven hunt can begin with information about an attacker or a known indicator. Our hunt begins with a behavior that we expect to find if a particular scenario occurs. We then search for evidence that supports or weakens that hypothesis. Threat intelligence can help us choose the behavior, but the matching records still need investigation.

This scenario is a new teaching example. We do not claim that PowerShell was used in the RSA case studied in Week 4.

Explain the data 2 to 3 minutes

Our dataset contains ten events on five fictional endpoints. Each endpoint has one process event and one network event. The fields include the timestamp, host identifier, event category, process identifier, process name, parent name and command line.

The process entity identifier is especially important. A host can run many programs at the same time. A network connection from a browser should not be attached to a PowerShell process simply because both are on the same computer.

LAB-01 represents a suspicious chain. LAB-02 represents an ordinary inventory script. LAB-03 represents approved reporting automation that happens to match our query. LAB-04 tests whether we incorrectly join events from different processes. LAB-05 uses an Office workflow without the encoded command argument.

The encoded argument in our dataset contains a placeholder. We never execute it. The IP addresses are documentation addresses, and the scripts do not contact them.

Explain the four searches 3 to 4 and a half minutes

The first search finds PowerShell process events. It returns five events. This gives us the initial set of activity to examine.

The second search adds the parent process condition. It keeps PowerShell launched by Word or Excel. Four events remain. The normal inventory activity launched from Explorer is removed.

The third search adds an encoded command argument. Three events remain. LAB-05 no longer matches because its command line does not contain that argument.

The final search correlates the candidate process with an outbound network event. It groups records by both host identifier and process entity identifier. It also checks that the network event occurs after the process event and within six hundred seconds.

Two candidates remain, LAB-01 and LAB-03. LAB-04 is excluded because its network record belongs to a different process. That control shows why host-only correlation would be too broad.

Please look at the results table in the report. It records how each condition reduces the set of events we need to review.

Review the candidates 4 and a half to 6 minutes

LAB-01 matches the complete sequence and has no approved automation context in our exercise. We classify it as a suspicious simulation that needs investigation. In a real environment, we would inspect the source document, process tree, script content and destination before making a final decision.

LAB-03 also matches the sequence. However, the exercise context identifies it as approved reporting automation. We classify it as benign matching activity, or a false positive if the hunt result were treated as an alert.

This is an important result. Two matches do not mean two compromises. The query finds candidates based on behavior. The analyst decides how that behavior relates to the environment.

We also avoid claiming detection accuracy from five fictional endpoints. This dataset tests the intended logic, including one false positive and one correlation control. It cannot estimate how the query performs on a real organization.

If presenting from a phone, show the results page and the saved output file. If a computer with Splunk is available, run the final query and show the two matching host identifiers. Do not describe a saved result as a live run.

Limitations and next increment 6 to 7 and a half minutes

The current hunt assumes that process and network telemetry are collected and normalized correctly. It may miss activity through an intermediate command shell, a different interpreter or a PowerShell command that does not use the selected encoded argument.

Our final query uses the earliest candidate and earliest outbound event per process. That is sufficient for this small dataset, where each process has only one relevant start and connection. More complex histories need a sequence-aware approach so an earlier unrelated network event does not hide a later relevant connection.

Our next step is to collect authorized lab telemetry and compare the hunt with normal Office workflows. We can examine script content, signer information and known approved automation. Any exception should have a clear reason and a review date.

The Week 5 files include the report, dataset, executed Splunk searches and recorded responses. The README explains how to repeat the experiment and commit the new increment to the group repository. The main lesson is that a hunt should start with a testable question and end with reviewed evidence. Thank you.

Short answers for teacher questions

- What is the hypothesis? Office launches encoded PowerShell, followed by outbound traffic from that same process within ten minutes.

- Why PowerShell? It supports administration and can also be abused for execution; context matters.
- Which platform was used? Splunk Enterprise; the exact version is recorded in the results.
- Are these real incident logs? No. The dataset is synthetic and clearly labeled.
- How many final matches? Two, LAB-01 and LAB-03.
- Why is LAB-03 benign? The exercise context identifies approved reporting automation. A real case requires independent verification.
- Why does LAB-04 not match? Its outbound connection belongs to a different process entity.
- Was a malicious command executed? No. The encoded argument is only a placeholder in a log field.
- What changed since Week 4? A testable hypothesis, normalized events, executed hunt queries and candidate review.
- Has it been pushed to GitHub? Check the actual group repository before answering; the delivered files are ready to upload.